CS-01 TP · BTS SIO 2E ANNÉE · CYBERSÉCURITÉ

Audit Active Directory et GPO

Audit d'un domaine de test avec PingCastle et BloodHound, corrections, puis trois GPO de restriction des postes.

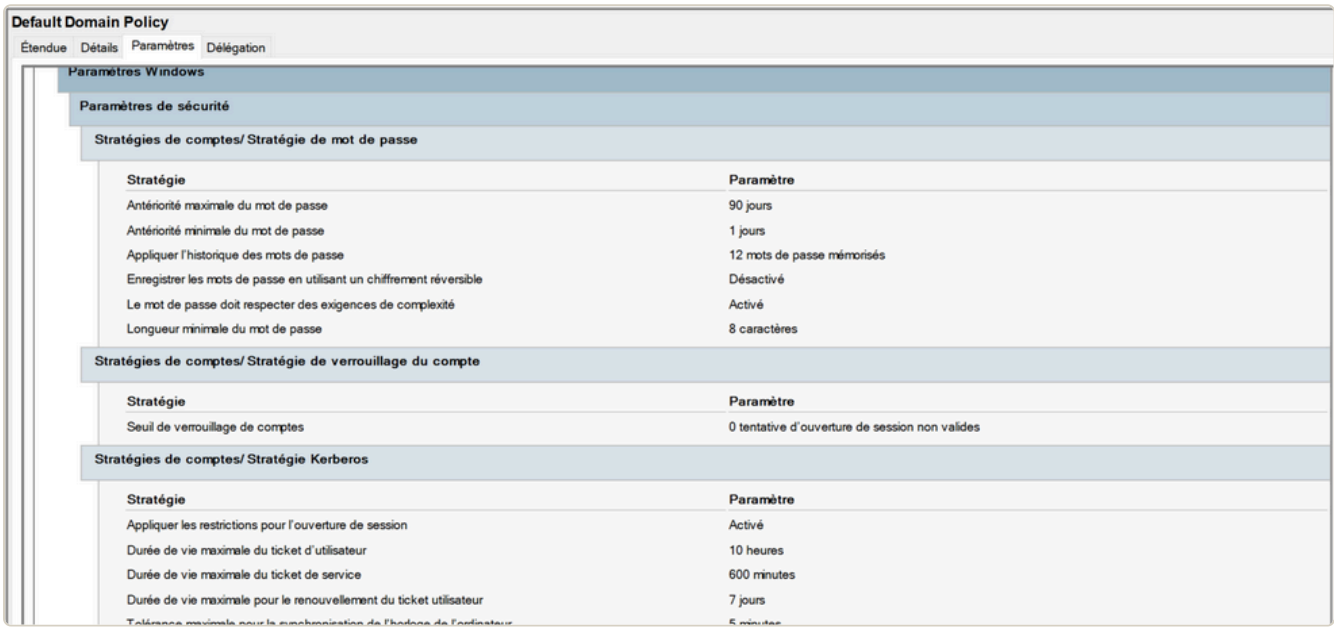
AUTEUR
Constant Segrétain

CONTEXTE
TP en cours, domaine de laboratoire constant.local

DATE
mars 2026

1. Point de départ : la politique de mots de passe

Relevé de la *Default Domain Policy* du domaine de test :

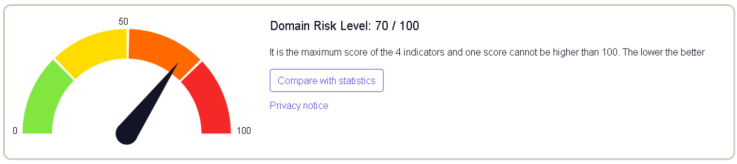


Paramètre	Valeur relevée
Longueur minimale	8 caractères
Complexité	activée
Historique	12 mots de passe
Durée de vie maximale / minimale	90 jours / 1 jour
Seuil de verrouillage	0 : le compte ne se verrouille jamais

L'absence de verrouillage laisse un attaquant essayer des mots de passe sans limite, et 8 caractères restent en dessous des recommandations de l'ANSSI pour des comptes à privilèges.

2. Audit avec PingCastle

PingCastle note le domaine sur 100 (plus le score est bas, mieux c'est) selon quatre familles : objets obsolètes, comptes à privilèges, relations d'approbation et anomalies.



Niveau de risque du domaine : 70/100.

Risk model

Left-click on the headlines in the boxes for more details

Stale Objects	Privileged accounts	Trusts	Anomalies
Inactive user or computer	Account take over	Old trust protocol	Audit
Network topography	ACL Check	SID Filtering	Backup
Object configuration	Admin control	SIDHistory	Certificate take over
Obsolete OS	Control paths	Trust impermeability	Golden ticket
Old authentication protocols	Delegation Check	Trust inactive	Local group vulnerability
Provisioning	Irreversible change	Trust with Entra	Network sniffing
Replication	Privilege control		Pass-the-credential
Vulnerability management	Read-Only Domain Controllers		Password retrieval
			Reconnaissance
			Temporary admins
			Weak password

Modèle de risque, audit initial.

Stale Objects	Privileged accounts	Trusts	Anomalies
Inactive user or computer	Account take over	Old trust protocol	Audit
Network topography	ACL Check	SID Filtering	Backup
Object configuration	Admin control	SIDHistory	Certificate take over
Obsolete OS	Control paths	Trust impermeability	Golden ticket
Old authentication protocols	Delegation Check	Trust inactive	Local group vulnerability
Provisioning	Irreversible change	Trust with Entra	Network sniffing
Replication	Privilege control		Pass-the-credential
Vulnerability management	Read-Only Domain Controllers		Password retrieval
			Reconnaissance
			Temporary admins
			Weak password

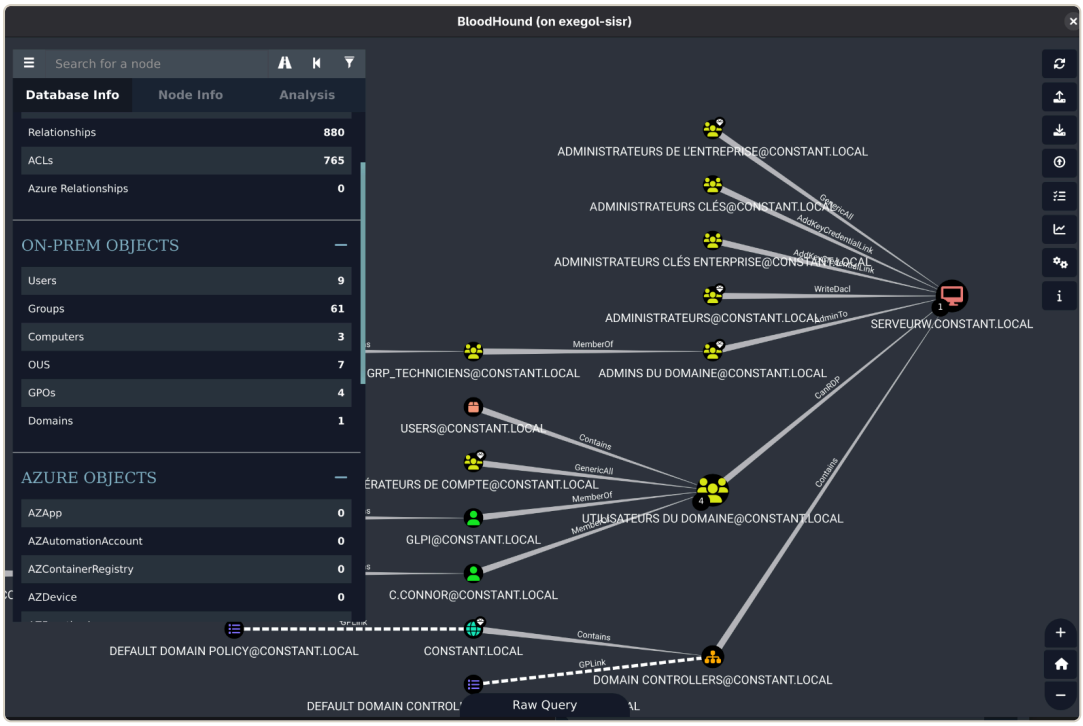
Après corrections.

Entre les deux audits, la case **Old authentication protocols** passe du orange au bleu : les protocoles d'authentification anciens ne sont plus signalés. Les autres points relevés (prise de contrôle de comptes, contrôle des administrateurs, sauvegarde, pass-the-credential) restent à traiter.

---

3. Chemins d'attaque avec BloodHound

BloodHound collecte les relations entre objets de l'annuaire (appartenance aux groupes, droits sur les objets, sessions) et les affiche en graphe. Il sert ici à vérifier qui peut, directement ou par rebond, obtenir les droits d'administrateur du domaine.



Graphe du domaine constant.local : groupes d'administration, utilisateurs et serveur.

---

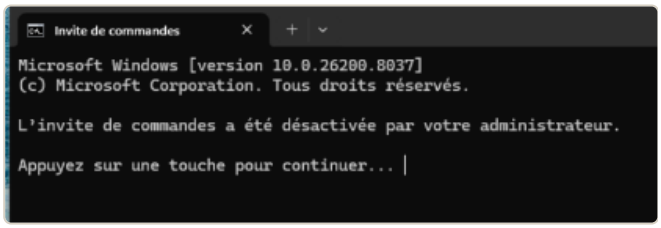
4. GPO de restriction des postes

Trois GPO appliquées aux utilisateurs standard, chacune vérifiée sur un poste client.

Désactiver l'invite de commandes

Configuration utilisateur → Modèles d'administration → Système → *Désactiver l'accès à l'invite de commandes*, y compris le traitement des scripts.



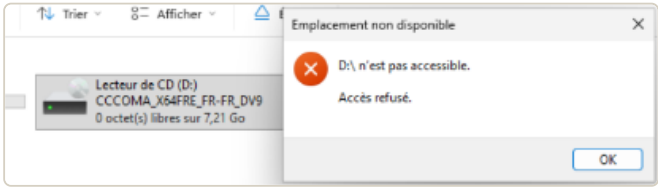


Résultat sur le poste.

Bloquer les supports amovibles

Système → Accès au stockage amovible : refus de lecture sur les CD/DVD et les disques amovibles. Limite les introductions de logiciels malveillants et les sorties de données.





Lecteur refusé.

Interdire le Panneau de configuration

Panneau de configuration → *Interdire l'accès au Panneau de configuration et à l'application Paramètres du PC.*





Message affiché à l'utilisateur.

---

5. Recommandations

- Activer un seuil de verrouillage (par exemple 5 essais) et passer la longueur minimale à 12 caractères, davantage pour les comptes d'administration (stratégie de mot de passe affinée).
- Traiter les points restants de PingCastle, en commençant par les comptes à privilèges.
- Relancer PingCastle et BloodHound après chaque changement pour mesurer l'effet.